

SEC-TC-F03: Autenticação Anônima Habilitada

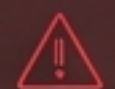
Análise de Vulnerabilidade, Prova de Conceito e Remediação Prescrita



Alvo:
98.95.207.28



Serviço / Porta:
vsftpd 3.0.5 | 21/TCP



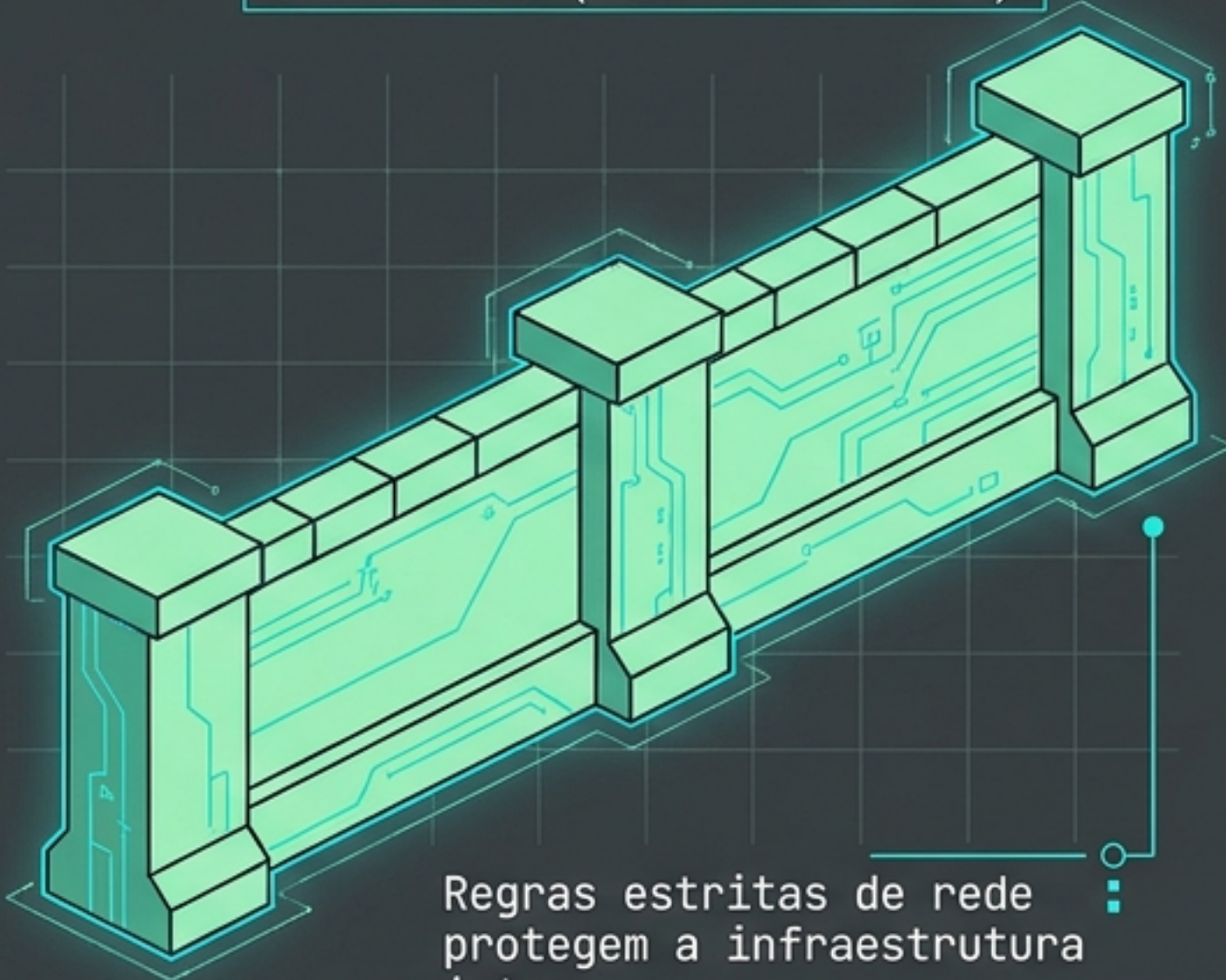
CVSS v3.1:
7.5 (ALTO)

PRESENTER ID

Consultor Principal de Segurança Ofensiva
(Red Team Lead)

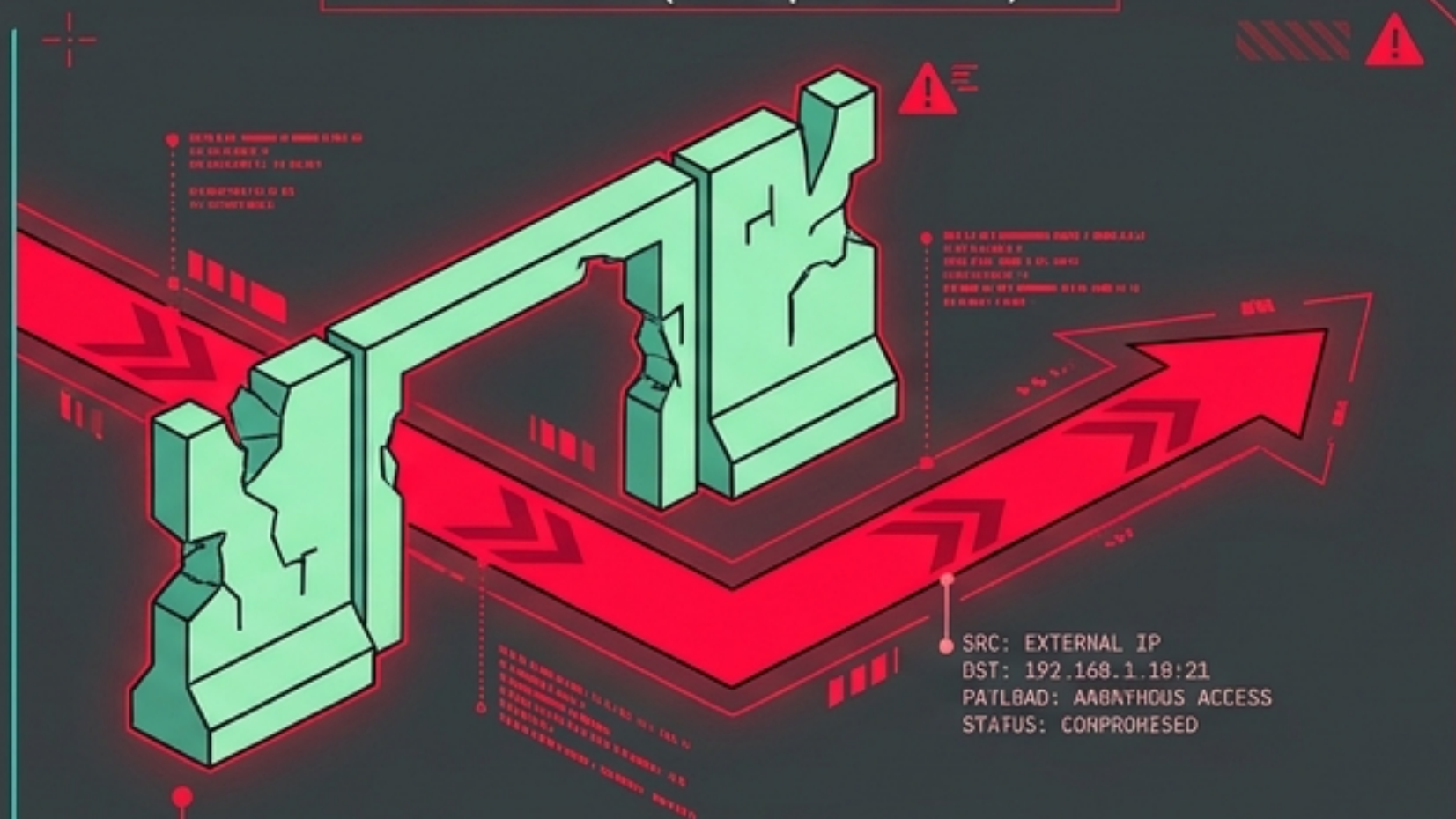
Contexto do Vetor: O Colapso da Segurança de Borda

Camada 3/4 (Firewall / Rede)



Regras estritas de rede protegem a infraestrutura interna.

Camada 7 (vsftpd 3.0.5)



Conexões públicas aceitas. O daemon aceita anonymous:anonymous, emitindo o código FTP 230 (Acesso Concedido).

A AUSÊNCIA DE CONTROLE DE ACESSO NA CAMADA DE APLICAÇÃO (L7) TORNA A PROTEÇÃO DE PERÍMETRO (L3/L4) IRRELEVANTE. O INVASOR JÁ ESTÁ DENTRO.

Prova de Conceito (PoC): Exploração Ativa

Reconhecimento (Nmap NSE)

```
$ nmap -p 21 --script ftp-anon 98.95.207.28
Starting Nmap 7.95 ( https://nmap.org ) at 2025-
11-27 19:16 -03
Nmap scan report for ec2-98-95-207-28.compute-1.am
azonaws.com (98.95.207.28)
Host is up (0.14s latency).
PORT      STATE SERVICE
21/tcp    open  ftp
| ftp-anon: Anonymous FTP login allowed (FTP code
230)
|_Can't get directory listing: PASV IP 172.20.0.20
is not the same as 98.95.207.28

Nmap done: 1 IP address (1 host up) scanned in 1.21
seconds
```

Intrusão (Sessão FTP)

```
$ ftp -n 98.95.207.28
> user anonymous anonymous
230 Login successful. Remote system type is UNIX.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp>
```

Acesso imediato ao sistema de arquivos compartilhado, burlando qualquer exigência de identificação prévia.

Análise de Impacto: A Cadeia de Intrusão (Blast Radius)

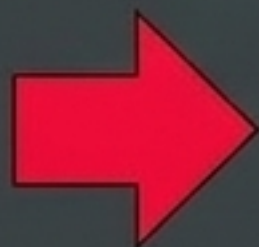
Kill Chain



0 Acesso (SEC-TC-F03)

Conexão anônima
estabelecida.

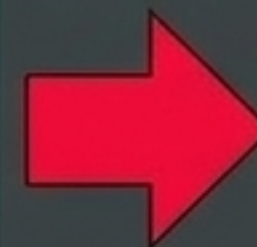
Princípio do menor
privilégio violado.



0 Mapa (SEC-TC-F04)

Descoberta e extração
do arquivo user.conf.

Enumeração de contas
corporativas.



As Chaves (SEC-TC-F05)

Extração do arquivo
passwords.txt em texto
claro.

Comprometimento total
de credenciais.

O impacto técnico primário é o acesso indevido ao FTP, mas o impacto real ao negócio é a perda total de confidencialidade da infraestrutura interna devido ao armazenamento inseguro subsequente.

Plano de Remediação Tática: Fechando a Porta

Alvo: /etc/vsftpd.conf

Code Diff

`[-] anonymous_enable=YES`

`[+] anonymous_enable=NO`

`[+] chroot_local_user=YES` (Boas práticas adicionais de confinamento)

Aplicação e Correção de Permissões

```
$ sudo chown root:root /etc/vsftpd/user.conf  
$ sudo chmod 600 /etc/vsftpd/user.conf  
$ sudo systemctl restart vsftpd
```

Ação Imediata: Bloqueio sumário de credenciais anônimas.

Recomendações Estratégicas e Evolução de Arquitetura

Matriz de Evolução: O Fim do FTP Legado

LAT: 36.8951 N
LON: 77.6364 W

FTP	Tráfego em texto claro, autenticação frágil (anônima), ausência total de auditoria confiável.
SFTP	Túnel SSH (Criptografia AES), autenticação por chaves assimétricas (ED25519), auditoria unificada.

LAT: 36.8951 N
LON: 77.6364 W

Próximos Passos (Next Actions)

LAT: 36.8951 N
LON: 77.6364 W

- 1

Mitigação (F03): Implantação imediata do hardening no vsftpd.
- 2

Expurgo: Remoção dos arquivos de configuração expostos e rotação imediata de senhas.
- 3

Próxima Pauta: Análise profunda dos artefatos vazados (SEC-TC-F04 e F05) e o impacto escalado no banco de dados.

LAT: 36.8951 N
LON: 77.6364 W

Descontinuar protocolos legados não é uma opção arquitetônica, é um requisito básico de conformidade.